



National Teachers College

College Department
629 Nepomuceno, Quiapo, Manila

Security Report :

FINDIT: Lost and Found Management System

Submitted By:

Arcilla, Ej
Berdejo, Justine Marlowie
Bitara, Peter John
Guico, Karlo Emanuel
King, Allen Marlon

Course/Block:

3.2 BSIT

Submitted To:

Mr. Edward James Grageda

Date:

May 30, 2026



National Teachers College

College Department
629 Nepomuceno, Quiapo, Manila

Introduction

Security is an essential aspect of web application development. The FINDIT Lost and Found Management System was developed with several security mechanisms to protect user information, prevent unauthorized access, and ensure the integrity of system operations.

This report outlines the security measures implemented within the system and explains how they contribute to maintaining a secure application environment.

Authentication and Authorization

The system implements session-based authentication to verify user identities before granting access to protected resources.

Implemented Controls

- User registration and login system
- Session management
- Logout functionality
- Role-based access control

After a successful login, session variables are created and maintained throughout the user's interaction with the system.

Administrative functions are restricted to users with administrator privileges.

Unauthorized users attempting to access administrative routes are redirected appropriately.



National Teachers College

College Department
629 Nepomuceno, Quiapo, Manila

Security Benefit

This prevents unauthorized users from accessing restricted system functionality and administrative controls.

Cross-Site Request Forgery (CSRF) Protection

The application utilizes CodeIgniter 4's built-in CSRF protection mechanism.

Implemented Controls

- CSRF protection enabled
- CSRF tokens included in forms
- Automatic token verification

Each form submission contains a unique token generated by the framework. Requests containing invalid or missing tokens are rejected before processing.

Security Benefit

This protects the application from malicious requests originating from external websites attempting to perform unauthorized actions on behalf of authenticated users.

Cross-Site Scripting (XSS) Prevention

The application protects against Cross-Site Scripting attacks through output escaping.

Implemented Controls

- Escaped output using CodeIgniter helper functions
- Sanitized display of user-generated content



National Teachers College

College Department
629 Nepomuceno, Quiapo, Manila

User-submitted data is escaped before being displayed in the browser using CodeIgniter's `esc()` helper.

Example:

```
<?= esc($item['item_name']) ?>
```

Security Benefit

This prevents attackers from injecting malicious JavaScript code into application pages.

Input Validation

The system validates user input before processing and storing information.

Implemented Controls

- Required field validation
- Image upload validation
- Server-side validation rules

Input fields are validated to ensure required data is provided and that uploaded files meet defined restrictions.

Example validations include:

- Item Name
- Category
- Description
- Location
- Status
- Uploaded Images



National Teachers College

College Department
629 Nepomuceno, Quiapo, Manila

Security Benefit

Input validation reduces the risk of malformed data, invalid submissions, and potential exploitation attempts.

File Upload Security

The application supports image uploads for reported items.

Implemented Controls

- Image-only uploads
- Maximum file size restrictions
- Randomized file names

Uploaded files are validated using CodeIgniter validation rules before being accepted and stored.

Security Benefit

Restricting file types helps prevent the upload of malicious executable files and other potentially harmful content.

Database Security

The application uses CodeIgniter's Query Builder and Model system for database interactions.

Implemented Controls

- Query Builder usage
- Parameterized database operations
- Model-based database access

Database operations are performed through CodeIgniter Models rather than direct SQL string concatenation.



National Teachers College

College Department
629 Nepomuceno, Quiapo, Manila

Security Benefit

This reduces the risk of SQL Injection attacks and improves database security.

Session Security

User sessions are used to maintain authenticated access.

Implemented Controls

- Session-based authentication
- Session validation
- Protected routes

Access to user and administrator functionality is verified through session variables before processing requests.

Security Benefit

This prevents unauthorized access to protected resources and administrative functions.

Security Testing

Several security-related checks were performed during development.

Activities Performed

- Form validation testing
- Authentication testing
- Authorization testing
- Route access verification
- Session validation testing
- Input handling verification

Debugging Tools Used

- CodeIgniter dd() function
- PHPUnit testing framework



National Teachers College

College Department
629 Nepomuceno, Quiapo, Manila

Conclusion

The FINDIT Lost and Found Management System implements multiple layers of security including authentication, authorization, CSRF protection, XSS prevention, input validation, secure file upload handling, database protection, and session management.

These measures help protect users, preserve data integrity, and improve overall application security while maintaining usability and functionality.

The implemented controls follow standard web application security practices and contribute to the reliability of the deployed system.